

Relatório Técnico: Atividade 12

Título: Sumário do Resultado — Análise Estática de Código (SAST) com SonarQube **Autor:** Cleydson Soares de Freitas

Data: 10/06/2026

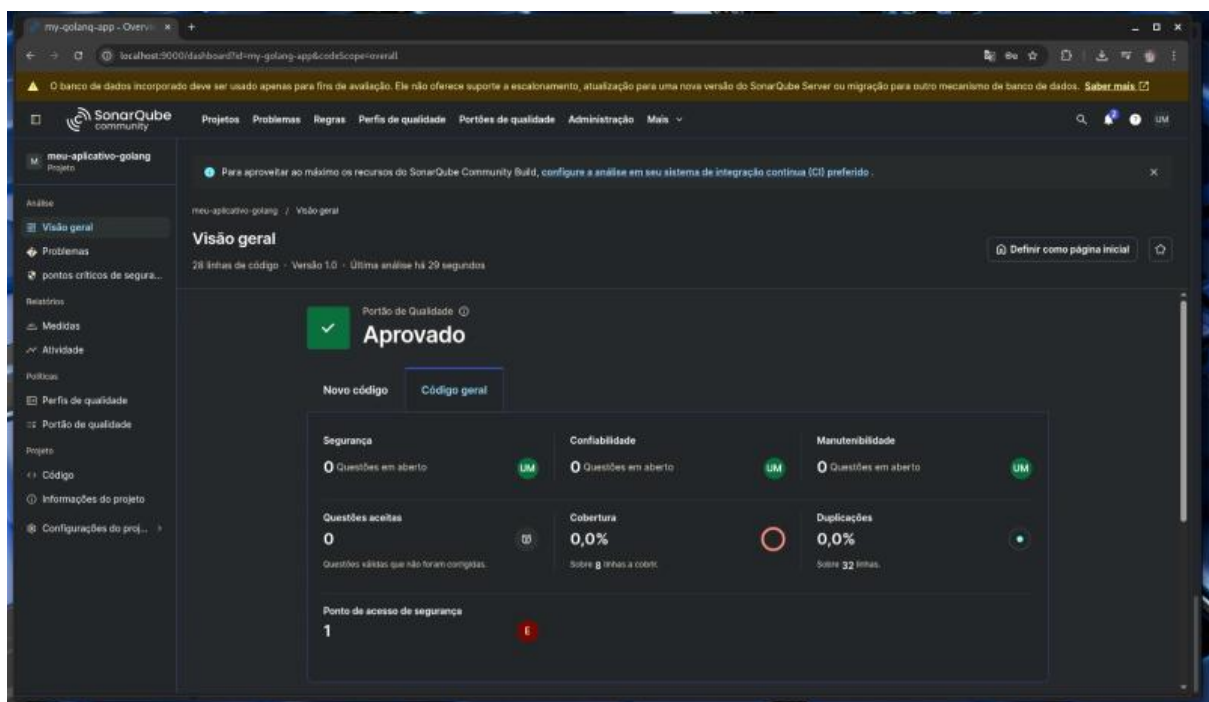
1. Objetivo

Integrar ferramentas de Análise Estática de Segurança de Aplicações (SAST) na esteira de CI, utilizando uma instância local do SonarQube para identificar vulnerabilidades, falhas de lógica (bugs) e code smells no código-fonte em Go.

2. Desenvolvimento e Resultados

- **Integração do Scanner:** Adição do estágio do SonarQube Scanner na pipeline após a fase de testes funcionais.
- **Análise de Segurança:** Configuração dos tokens de autenticação e comunicação entre o runner local e o servidor do SonarQube. O scanner realizou a varredura estática completa da aplicação, mapeando o código linha por linha sem executá-lo.
- **Resultados:** O código foi submetido às regras padrão de qualidade (Quality Gate), gerando o relatório de métricas de cobertura de testes, densidade de duplicidade de código e mapeamento de possíveis brechas de segurança.

3. Evidências do Processo



SonarQube

localhost:9000/profile/show?name=HDB&language=go

Embedded database should be used for evaluation purposes only. It doesn't support scaling, upgrading to a new SonarQube Server version, or migration to another database engine. [Learn more](#)

SonarQube

community

ProjectsIssuesRulesQuality profilesQuality gatesAdministrationMore

Search

Notifications

Help

Logout

Quality profiles / Go / HDB

HDB

Updated: 50 seconds agoUsed: NeverSee Changelog

Inheritance

Change Parent

Sonar way	Built-in	22 active rules	14 inactive rules	0 overridden rules
HDB		22 active rules	14 inactive rules	0 overridden rules

Projects

Change Projects

my-golang-app

1 of 1 shown

Permissions

Users with the global "Administer Quality Profiles" permission and those listed below can manage this quality profile.

Grant permissions to more users

Rule breakdown

Software qualities	Active	Inactive
Security	0	0
Reliability	6	1
Maintainability	16	13

Code categories	Active	Inactive
Consistency	4	4
Intentionality	12	3
Adaptability	6	6
Responsibility	0	1

Activate More

Rules - SonarQube Com

localhost:9000/coding_rules?languages=go&selected=go%3A5126

O banco de dados incorporado deve ser usado apenas para fins de avaliação. Ele não oferece suporte a escalonamento, atualização para uma nova versão do SonarQube Server ou migração para outro mecanismo de banco de dados. [Saber mais](#)

SonarQube

community

ProjetosProblemasRegrasPerfis de qualidadePortões de qualidadeAdministraçãoMais

Search

Notifications

Help

Logout

Filtros

Limpar todos os filtros

Procurando por bugs, vulnerabilidades ou problemas de código? Se sua equipe prefere trabalhar com esses tipos, altere nas configurações.

Linguagem

Go

Gerenciamento de Recursos d...

Go

2 de 2 mostrados

Adicionar à seleção

Qualidade do software

Segurança

Confiabilidade

Manutenibilidade

Ponto de acesso de segurança

Mostrar apenas os hotspots de...

Gravidade

Bloqueador

Procurar por regras...

Troco em massa

Regras de seleção

Navegue até a regra

36 regras

"if ... else if" constructs should end with "else" clauses

Maintainability

High

Intentionality

Go

"switch case" clauses should not have too many lines

Maintainability

Medium

Adaptability

Go

"switch" statements should have "default" clauses

Maintainability

High

Intentionality

Go

"switch" statements should not be nested

Maintainability

High

Adaptability

Go

"switch" statements should not have too many "case" clauses

Maintainability

Medium

Adaptability

Go

All branches in a conditional structure should not have exactly the same implementation

Reliability

Medium

Intentionality

Go

All code should be reachable

Reliability

Medium

Intentionality

Go

Boolean checks should not be inverted

Consistency

The terminal window shows the installation of SonarScanner CLI and its execution. The first run fails due to an unauthorized request to the SonarQube server. The second run, with the correct Sonar token, succeeds and shows the scanner configuration and project details.

```
13:48:06.703 INFO Project root configuration file: /usr/src/sonar-project.properties
13:48:06.792 INFO SonarScanner CLI 6.0.1.0346
13:48:06.795 INFO Linux 6.18.3-kali2-amd64 amd64
13:48:06.826 WARN Both 'sonar.login' and 'sonar.token' (or the 'SONAR_TOKEN' env variable) are set, but only the latter will be used.
13:48:07.432 ERROR Failed to query server version: GET http://localhost:9000/api/v2/analysis/version failed with HTTP 401 Unauthorized. Please check the property sonar.token or the environment variable SONAR_TOKEN.
13:48:07.432 INFO EXECUTION FAILURE
13:48:07.433 INFO Total time: 0.655s

[cleydsom@cleydsom:~/my-golang-app]
$ cd ~/my-golang-app/
$ docker restart sonarqube
sleep 30
$ docker run --rm -v "${PWD}:/usr/src" --network=host sonarsource/sonar-scanner-cli -Dsonar.projectKey=my-golang-app -Dsonar.sources=. -Dsonar.host.url=http://localhost:9000 -Dsonar.login=admin -Dsonar.password=Gabr
13:49:28.961 INFO Scanner configuration file: /opt/sonar-scanner/conf/sonar-scanner.properties
13:49:28.964 INFO Project root configuration file: /usr/src/sonar-project.properties
13:49:28.973 INFO SonarScanner CLI 6.0.1.0346
13:49:28.976 INFO Linux 6.18.3-kali2-amd64 amd64
13:49:29.085 WARN Both 'sonar.login' and 'sonar.token' (or the 'SONAR_TOKEN' env variable) are set, but only the latter will be used.
13:49:29.579 ERROR Failed to query server version: GET http://localhost:9000/api/v2/analysis/version failed with HTTP 401 Unauthorized. Please check the property sonar.token or the environment variable SONAR_TOKEN.
13:49:29.580 INFO EXECUTION FAILURE
13:49:29.580 INFO Total time: 0.621s

[cleydsom@cleydsom:~/my-golang-app]
$ cd ~/my-golang-app/
$ docker run --rm -v "${PWD}:/usr/src" --network=host sonarsource/sonar-scanner-cli -Dsonar.projectKey=my-golang-app -Dsonar.sources=. -Dsonar.host.url=http://localhost:9000 -Dsonar.token=uqa_4d09b6abc96da6e25a8d70
13:59:09.696 INFO Scanner configuration file: /opt/sonar-scanner/conf/sonar-scanner.properties
13:59:09.698 INFO Project root configuration file: /usr/src/sonar-project.properties
13:59:09.740 INFO SonarScanner CLI 6.0.1.0346
13:59:09.711 INFO Linux 6.18.3-kali2-amd64 amd64
13:59:10.312 INFO Communicating with SonarQube Community Build 26.6.0.123539
13:59:10.313 INFO JRE provisioning: os[linux], arch[amd64]
13:59:11.629 INFO Starting SonarScanner Engine...
13:59:11.629 INFO Java 21.0.9 Eclipse Adoptium (64-bit)
13:59:12.335 INFO Load global settings
13:59:12.396 INFO Load global settings (done) | time=59ms
13:59:12.397 INFO Server id: 1476411e-A26na9oKXABd10T205c7
13:59:12.403 INFO Loading required plugins
13:59:12.403 INFO Load plugins index
13:59:12.419 INFO Load plugins index (done) | time=15ms
13:59:12.419 INFO Load/download plugins
13:59:12.587 INFO Load/download plugins (done) | time=169ms
13:59:12.734 INFO Process project properties
13:59:12.741 INFO Process project properties (done) | time=7ms
13:59:12.748 INFO Project key: my-golang-app
13:59:12.748 INFO Base dir: /usr/src
13:59:12.748 INFO Working dir: /tmp/.scannerwork
13:59:12.754 INFO Load project settings for component key: 'my-golang-app'
13:59:12.773 INFO Load project settings for component key: 'my-golang-app' (done) | time=10ms
13:59:12.784 INFO Load quality profiles
13:59:12.893 INFO Load quality profiles (done) | time=100ms
13:59:12.922 INFO Load active rules
13:59:13.259 INFO Load active rules (done) | time=338ms
13:59:13.263 INFO Load analysis cache
13:59:13.271 INFO Load analysis cache (404) | time=8ms
```

The SonarQube web interface shows a list of projects and their quality profiles. The 'Sonar way' profile is highlighted, showing a score of 36 and 47 minutes ago. A tooltip for the 'Sonar way' profile is visible, showing the profile name and the score.

Project	Quality Profile	Rules	Updated	Used
CloudFormation, 1 profile(s)	Projects	Rules	Updated	Used
Sonar way, Built-in	DEFAULT	36	47 minutes ago	Never
Docker, 1 profile(s)	Projects	Rules	Updated	Used
Sonar way, Built-in	DEFAULT	25	47 minutes ago	17 minutes ago
Flex, 1 profile(s)	Projects	Rules	Updated	Used
Sonar way, Built-in	DEFAULT	47	47 minutes ago	Never
Go, 2 profile(s)	Projects	Rules	Updated	Used
Sonar way, Built-in	0	22	47 minutes ago	17 minutes ago
HDB	DEFAULT	22	13 minutes ago	Never
HTML, 1 profile(s)	Projects	Rules	Updated	Used
Scanner sonar, Built-in	DEFAULT	CS	47 minutes ago	Never

4. Conclusão

A inclusão do SonarQube na esteira demonstrou como auditar a qualidade e a segurança do software de forma contínua. Mapear vulnerabilidades diretamente na pipeline impede que códigos fora dos padrões de segurança avancem no ciclo de desenvolvimento.\